

# SENTINEL

ELVIS SYSTEMS INDUSTRIAS

Sistema de auditoría y remediación asistida de seguridad para equipos Windows. Detecta la exposición real de un equipo, la explica en lenguaje claro y aplica la corrección con autorización explícita del usuario.

|                                                                               |                                                                                               |                                                            |
|-------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|------------------------------------------------------------|
| <div>EMPRESA DE APLICACIÓN</div> <div>GUE Mariano Melgar · Arequipa</div>     | <div>ÁREA INTERVENIDA</div> <div>Laboratorio de cómputo / Aula de Innovación Pedagógica</div> | <div>AUTOR</div> <div>Elvis Alberto Huaynari Rivera</div>  |
| <div>CARRERA Y SEMESTRE</div> <div><u>completar</u></div>                     | <div>DOCENTE ASESOR</div> <div><u>completar</u></div>                                         | <div>PLATAFORMA</div> <div>Windows 10 y 11 (64 bits)</div> |
| <div>ESTADO DEL PRODUCTO</div> <div>Funcional, empaquetado y verificado</div> | <div>ALCANCE</div> <div>Estrictamente defensivo y local</div>                                 |                                                            |

01

## Resumen ejecutivo

La mayoría de equipos Windows en instituciones educativas operan con la configuración de fábrica: protocolos obsoletos activos, servicios de acceso remoto habilitados sin necesidad, programas desconocidos arrancando con el sistema y ningún registro de quién revisó qué, ni cuándo. No es un problema de falta de antivirus: es un problema de **configuración no auditada**.

SENTINEL ataca ese hueco. Es una aplicación de escritorio que en menos de un minuto levanta el estado de seguridad real de un equipo, le asigna un **puntaje de blindaje del 0 al 100**, explica cada hallazgo en lenguaje que un docente entiende y aplica la corrección con un clic, siempre pidiendo permiso de administrador. Nunca modifica el sistema en silencio.

**Diferencia respecto a un antivirus.** Un antivirus busca archivos maliciosos ya conocidos. SENTINEL audita *cómo está configurado el equipo* y qué comportamientos anómalos ocurren ahora mismo: procesos que suplantan nombres del sistema, puertos peligrosos expuestos a la red y mecanismos de persistencia en el arranque. Son capas distintas. SENTINEL complementa a Windows Defender, no lo reemplaza.

#### CIFRAS DEL PRODUCTO

| ESTADO VERIFICADO DEL DESARROLLO |              |                                                                  |
|----------------------------------|--------------|------------------------------------------------------------------|
| Código propio en Python          | 2 469 líneas | 19 módulos organizados en motor, interfaz y herramientas         |
| Interfaz web embebida            | 1 515 líneas | Panel de operaciones con orbe de estado en tiempo real           |
| Clases de hallazgo               | 8            | Sobre procesos, red y arranque automático                        |
| Controles de blindaje auditados  | 5            | Con corrección automática disponible en los cinco                |
| Acciones ejecutables por voz     | 7            | El asistente actúa, no solo aconseja                             |
| Empaquetado                      | OK           | Ejecutable independiente verificado, no requiere instalar Python |

## El problema que resuelve

Un laboratorio de cómputo escolar concentra condiciones que en seguridad informática se consideran de alto riesgo, y lo hace sin personal técnico dedicado que las vigile:

|                                                                                                                                                                                             |                                                                                                                                                                                                             |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>VECTOR 01</p> <p><b>Equipos compartidos</b></p> <p>Decenas de usuarios distintos por semana sobre la misma máquina. Cualquiera puede dejar algo instalado y nadie lo nota.</p>           | <p>VECTOR 02</p> <p><b>Medios extraíbles</b></p> <p>Las memorias USB circulan entre casa, cabina de internet y colegio. Es la vía de contagio histórica en el sector educativo.</p>                         |
| <p>VECTOR 03</p> <p><b>Configuración de fábrica</b></p> <p>Windows llega con servicios y protocolos habilitados que un aula no necesita, y que nadie desactiva porque nadie los audita.</p> | <p>VECTOR 04</p> <p><b>Red plana</b></p> <p>Si un equipo queda comprometido, los demás están a un salto de distancia dentro de la misma red del laboratorio.</p>                                            |
| <p>VECTOR 05</p> <p><b>Sin medición</b></p> <p>No existe un indicador del estado de seguridad. Sin número no hay diagnóstico, y sin diagnóstico no hay mejora demostrable.</p>              | <p>VECTOR 06</p> <p><b>Revisión manual inviable</b></p> <p>Comprobar a mano los cinco controles críticos toma cerca de quince minutos por equipo. Multiplicado por el laboratorio completo, no se hace.</p> |

**El dato que convierte esto en proyecto.** La afirmación anterior es una hipótesis hasta que la midas. La auditoría inicial con SENTINEL sobre los equipos del laboratorio es la que produce la línea base del Capítulo III del PIM: cuántos equipos tienen SMBv1 activo, cuántos el firewall apagado, cuántos el escritorio remoto habilitado sin usarlo. Ese cuadro de frecuencias es tu diagrama de Pareto, y sale del propio sistema.

## Qué hace SENTINEL hoy

Cuatro motores independientes que alimentan un mismo panel. Todo lo descrito en esta sección está implementado y funcionando; no es plan ni intención.

### 3.1 Motor de vigilancia

Realiza un barrido de **solo lectura** del propio equipo cada sesenta segundos, en tres frentes. Cada hallazgo se emite con severidad, explicación en lenguaje claro y evidencia técnica adjunta (identificador de proceso, ruta, puerto, dirección remota).

| REGLAS DE DETECCIÓN IMPLEMENTADAS |                                                                                                                                                   |             |                                                                                                              |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|-------------|--------------------------------------------------------------------------------------------------------------|
| FRENTE                            | QUÉ DETECTA                                                                                                                                       | SEVERIDAD   | POR QUÉ IMPORTA                                                                                              |
| Procesos                          | Proceso del sistema ( <code>svchost.exe</code> , <code>lsass.exe</code> , <code>winlogon.exe</code> y otros nueve) ejecutándose fuera de System32 | CRÍTICA     | Patrón clásico de malware que adopta el nombre de un componente de Windows para pasar inadvertido            |
| Procesos                          | Ejecutable corriendo desde Temp, Descargas o carpeta Pública                                                                                      | MEDIA       | El software legítimo se instala antes de ejecutarse; correr desde ahí es propio de un adjunto recién abierto |
| Red                               | Puertos de alto riesgo expuestos a todas las interfaces: 23 Telnet, 445 SMB, 3389 RDP, 5900 VNC                                                   | ALTA        | Son las puertas de entrada más explotadas contra equipos Windows en red                                      |
| Red                               | Puertos de riesgo medio: 135 RPC, 139 NetBIOS, 1433 SQL Server, 3306 MySQL                                                                        | MEDIA       | Servicios que rara vez deben ser alcanzables desde fuera del equipo                                          |
| Red                               | Cualquier otro puerto a la escucha en o.o.o.o                                                                                                     | BAJA        | Superficie de ataque no justificada; se revisa que sea esperado                                              |
| Red                               | Conexiones salientes establecidas hacia direcciones IP públicas, con el proceso responsable                                                       | INFORMATIVA | Base para identificar tráfico de mando y control desde el equipo                                             |
| Arranque                          | Entradas <code>Run</code> y <code>RunOnce</code> del registro (HKCU y HKLM) que apuntan a rutas temporales                                        | ALTA        | Mecanismo de persistencia más usado: el malware se asegura de volver tras cada reinicio                      |
| Arranque                          | Inventario completo de programas de arranque y de la carpeta Inicio                                                                               | INFORMATIVA | Permite comparar contra una línea base y detectar lo que no estaba antes                                     |

DETALLE DE CALIDAD: EL FIREWALL SE TOMA EN CUENTA

Si un puerto de riesgo está a la escucha pero existe una regla de firewall que bloquea el acceso entrante, SENTINEL no lo reporta como amenaza: lo reclasifica como RIESGO MITIGADO. La detección evalúa la exposición real, no la simple presencia del puerto. Esta consulta se mantiene en memoria durante veinte segundos para no penalizar el rendimiento del equipo.

3.2 Auditoría de blindaje y puntaje

Cinco controles críticos de configuración de Windows, consultados en modo lectura. Cada uno devuelve estado, explicación, recomendación y el comando exacto que lo corrige. El conjunto produce el **puntaje de blindaje**, indicador principal del proyecto: correcto suma un punto, advertencia medio punto, fallo cero.

| CONTROLES AUDITADOS Y CORRECCIÓN DISPONIBLE |                                                          |                                                                                                       |
|---------------------------------------------|----------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| CONTROL                                     | CONDICIÓN EVALUADA                                       | RIESGO SI FALLA                                                                                       |
| Windows Defender                            | Antivirus y protección en tiempo real activos            | El equipo queda sin la única defensa contra código malicioso conocido                                 |
| Firewall de Windows                         | Habilitado en los perfiles de dominio, privado y público | Todos los servicios locales quedan alcanzables desde la red del laboratorio                           |
| Control de cuentas (UAC)                    | Valor <code>EnableLUA</code> igual a 1                   | Cualquier programa puede elevar privilegios sin pedir confirmación                                    |
| Escritorio remoto (RDP)                     | Conexiones remotas denegadas si no se usan               | Vía de acceso remoto habitual para ataques de fuerza bruta contra contraseñas                         |
| Protocolo SMBv1                             | Característica deshabilitada en el sistema               | Protocolo obsoleto que WannaCry aprovechó en 2017 para propagarse solo entre equipos de una misma red |



Puntaje de blindaje – medición real en equipo de prueba

61 / 100

Ese 61 es una medición real tomada durante el desarrollo, con el protocolo SMBv1 activo y el puerto 445 expuesto. Es exactamente el tipo de número que vas a levantar en el laboratorio, y el que debe subir después de la intervención.

### 3.3 Análisis bajo demanda

El usuario arrastra un archivo o pega una dirección web y obtiene un veredicto. Pensado para el momento real de riesgo: alguien recibe algo por correo y no sabe si abrirlo.

| CRITERIOS DE EVALUACIÓN POR TIPO DE OBJETIVO |                                                                                                                                                                                                    |
|----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| OBJETIVO                                     | INDICADORES EVALUADOS                                                                                                                                                                              |
| Archivo                                      | Huella digital SHA-256, tamaño, ubicación en carpetas temporales, extensión ejecutable de riesgo (veinte extensiones controladas) y doble extensión engañosa del tipo <code>factura.pdf.exe</code> |
| Dirección web                                | Uso de dirección IP en lugar de dominio, ausencia de HTTPS, dominios con codificación punycode que imitan visualmente otros nombres, extensiones de dominio de alto abuso y longitud anómala       |
| Huella digital                               | Consulta directa de reputación sobre un hash entregado por un tercero                                                                                                                              |

Los indicadores suman un puntaje de riesgo que produce el veredicto final: PELIGROSO, SOSPECHOSO o SIN SEÑALES DE PELIGRO. Si se configura una clave de VirusTotal, el veredicto incorpora además cuántos motores antivirus del mundo marcan ese archivo como malicioso. La consulta es opcional: el análisis local funciona sin internet.

CUARENTENA REVERSIBLE

Ante un archivo peligroso, SENTINEL ofrece aislarlo: lo mueve a una carpeta controlada, lo renombra para que no pueda ejecutarse y guarda un registro con su ruta original y la fecha exacta. **Nunca borra nada.** Toda acción es reversible, principio irrenunciable cuando se opera sobre equipos que no son propios.

### 3.4 Cerebro, voz y capacidad de acción

La capa que convierte el reporte técnico en algo utilizable por alguien sin formación en seguridad, y el aporte diferencial del proyecto.

|                                                                                                                                                                                                      |                                                                                                                                                                                                                              |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>SIEMPRE DISPONIBLE</div> <div><b>Resumen heurístico</b></div> <div>Prioriza y redacta el estado del equipo en una frase, sin internet ni servicios externos. Es el modo base garantizado.</div> | <div>OPCIONAL</div> <div><b>Explicación ampliada</b></div> <div>Con clave configurada, un modelo de lenguaje redacta la guía de remediación priorizada. Si falla, el sistema sigue operando con el resumen heurístico.</div> |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|                                                                                                                                                                                               |                                                                                                                                                                                                                                      |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>NATIVO DE WINDOWS</div> <div><b>Alerta hablada</b></div> <div>Las amenazas nuevas se anuncian por voz con el sintetizador del propio sistema operativo, sin dependencias externas.</div> | <div>CONVERSACIONAL</div> <div><b>Asistente de voz bidireccional</b></div> <div>Escucha y responde en tiempo real con el estado del equipo inyectado en su contexto, sobre un hilo independiente para no bloquear la interfaz.</div> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

La diferencia frente a un asistente que solo conversa: SENTINEL **ejecuta**. Dispone de siete herramientas reales que puede invocar cuando el usuario se lo pide en lenguaje natural, y confirma con el resultado verdadero de la operación, incluido el fallo.

| HERRAMIENTAS EJECUTABLES POR EL ASISTENTE |                                                                |              |
|-------------------------------------------|----------------------------------------------------------------|--------------|
| HERRAMIENTA                               | ACCIÓN REAL QUE REALIZA                                        | REQUIERE UAC |
| security_report                           | Entrega el estado de seguridad vigente                         | No           |
| scan_now                                  | Fuerza un barrido inmediato                                    | No           |
| analyze_target                            | Evalúa un archivo, dirección web o huella digital              | No           |
| close_port                                | Crea una regla de firewall que bloquea el puerto indicado      | Sí           |
| enable_firewall                           | Activa el firewall en todos los perfiles                       | Sí           |
| fix_hardening                             | Aplica cualquiera de los cinco blindajes auditados             | Sí           |
| neutralize_threat                         | Termina un proceso malicioso o elimina una entrada de arranque | Sí           |

ESCALA DE SEVERIDAD DEL SISTEMA

|                                                                                               |                                                                                             |                                                                                     |
|-----------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <div>CRÍTICA</div> <div>Indicio directo de compromiso.<br/>Requiere atención inmediata.</div> | <div>ALTA</div> <div>Exposición explotable o persistencia sospechosa.</div>                 | <div>MEDIA</div> <div>Configuración débil o comportamiento inusual a revisar.</div> |
| <div>BAJA</div> <div>Superficie de ataque no justificada.</div>                               | <div>INFORMATIVA</div> <div>Inventario y contexto para comparar contra la línea base.</div> |                                                                                     |

# Base normativa y técnica

Ninguna regla de SENTINEL se escribió por intuición. Cada detección responde a una técnica de ataque documentada internacionalmente, y cada control de blindaje a una recomendación de endurecimiento reconocida. Esta sección es la que sostiene el marco teórico del proyecto.

## 4.1 Correspondencia con MITRE ATT&CK

MITRE ATT&CK es el catálogo internacional de técnicas reales empleadas por atacantes, mantenido por la corporación MITRE y adoptado como lenguaje común por la industria de seguridad.

| DETECCIÓN IMPLEMENTADA FRENTE A TÉCNICA CATALOGADA |                                                        |                                                                        |
|----------------------------------------------------|--------------------------------------------------------|------------------------------------------------------------------------|
| CÓDIGO                                             | TÉCNICA                                                | DETECCIÓN DE SENTINEL                                                  |
| T1036.005                                          | Suplantación: nombre o ubicación legítima              | Proceso del sistema ejecutándose fuera de System32                     |
| T1036.007                                          | Suplantación: doble extensión de archivo               | Detección de <code>archivo.pdf.exe</code> en el análisis bajo demanda  |
| T1204.002                                          | Ejecución por el usuario: archivo malicioso            | Ejecutable corriendo desde Temp o Descargas                            |
| T1547.001                                          | Persistencia: claves Run del registro y carpeta Inicio | Barrido de HKCU, HKLM y ambas carpetas de Inicio                       |
| T1021.001                                          | Servicios remotos: escritorio remoto                   | Puerto 3389 expuesto y control de blindaje de RDP                      |
| T1021.002                                          | Servicios remotos: SMB y recursos administrativos      | Puerto 445 expuesto y control de SMBv1                                 |
| T1021.005                                          | Servicios remotos: VNC                                 | Puerto 5900 expuesto                                                   |
| T1071                                              | Mando y control sobre protocolo de aplicación          | Conexiones salientes a direcciones IP públicas con proceso responsable |
| T1566.002                                          | Suplantación de identidad mediante enlace              | Análisis de direcciones web: punycode, IP directa, ausencia de HTTPS   |

## 4.2 Correspondencia con CIS Benchmarks

Los CIS Benchmarks del Center for Internet Security son la referencia mundial de configuración segura de sistemas. Los cinco controles auditados por SENTINEL pertenecen a sus áreas de endurecimiento de Windows.



| CONTROL AUDITADO Y ÁREA DEL BENCHMARK |                                                                    |
|---------------------------------------|--------------------------------------------------------------------|
| CONTROL DE SENTINEL                   | ÁREA DEL CIS BENCHMARK PARA WINDOWS                                |
| Windows Defender                      | Microsoft Defender Antivirus — protección en tiempo real           |
| Firewall de Windows                   | Windows Defender Firewall — perfiles de dominio, privado y público |
| Control de cuentas (UAC)              | Opciones de seguridad local — Control de cuentas de usuario        |
| Escritorio remoto                     | Plantillas administrativas — Servicios de Escritorio remoto        |
| SMBv1                                 | Configuración de red MS — cliente y servidor SMB v1                |

Nota metodológica: la numeración exacta de cada control varía entre versiones del benchmark. En el documento final, cita la versión que consultes.

## 4.3 Cobertura del marco NIST de ciberseguridad

El NIST Cybersecurity Framework organiza la seguridad en funciones. SENTINEL cubre cuatro de ellas, con distinto alcance:

| FUNCIONES CUBIERTAS POR EL SISTEMA |             |                                                                                |
|------------------------------------|-------------|--------------------------------------------------------------------------------|
| FUNCIÓN                            | COBERTURA   | CÓMO LA CUMPLE                                                                 |
| Identificar                        | COMPLETA    | Inventario de procesos, puertos, conexiones y programas de arranque del equipo |
| Proteger                           | COMPLETA    | Aplicación de los cinco blindajes y bloqueo de puertos por firewall            |
| Detectar                           | COMPLETA    | Vigilancia continua cada sesenta segundos con alerta inmediata                 |
| Responder                          | PARCIAL     | Cuarentena reversible y neutralización; sin gestión formal de incidentes       |
| Recuperar                          | NO CUBIERTA | Fuera del alcance actual; se declara como limitación                           |

## 4.4 Relación con ISO/IEC 27001

Si el jurado pregunta por normas de gestión, SENTINEL aporta evidencia técnica para cuatro controles del Anexo A: protección contra código malicioso, gestión de vulnerabilidades técnicas, gestión de la configuración y actividades de seguimiento y supervisión.

# Arquitectura y tecnología

Separación estricta entre el motor de seguridad y la interfaz. El motor funciona por sí solo desde consola, lo que permite auditar un equipo sin abrir la ventana gráfica: útil cuando hay que recorrer un laboratorio completo.

| MÓDULOS PRINCIPALES DEL SISTEMA |                                                             |        |
|---------------------------------|-------------------------------------------------------------|--------|
| MÓDULO                          | RESPONSABILIDAD                                             | LÍNEAS |
| core/monitor                    | Motor de vigilancia de procesos, red y arranque             | 452    |
| core/voice_live                 | Asistente de voz bidireccional en hilo propio               | 282    |
| core/analysis                   | Análisis de archivos, direcciones web y huellas; cuarentena | 236    |
| ui/window                       | Ventana principal y carga del panel de operaciones          | 216    |
| core/hardening                  | Auditoría de los cinco controles de blindaje                | 192    |
| core/agent_tools                | Herramientas ejecutables por el asistente                   | 182    |
| ui/scan_worker                  | Barrido periódico en segundo plano                          | 133    |
| core/license                    | Licenciamiento firmado sin servidor                         | 118    |
| ui/bridge                       | Puente entre el motor y la interfaz web                     | 112    |
| core/brain                      | Resumen, priorización y explicación de hallazgos            | 109    |
| core/config                     | Carga de configuración                                      | 67     |
| core/fixer                      | Aplicación de correcciones con elevación                    | 38     |

PILA TECNOLÓGICA

|                      |                              |                                                                                            |
|----------------------|------------------------------|--------------------------------------------------------------------------------------------|
| Lenguaje del motor   | Python 3                     | Inspección del sistema mediante <code>psutil</code> y acceso nativo al registro de Windows |
| Interfaz             | PyQt6 con motor web embebido | Panel de operaciones en tecnología web dentro de una ventana de escritorio nativa          |
| Consultas al sistema | PowerShell                   | Lectura del estado de Defender, firewall, UAC, RDP y SMBv1                                 |
| Concurrencia         | Hilos independientes         | La auditoría lenta corre en su propio hilo; la interfaz nunca se congela                   |
| Distribución         | Ejecutable independiente     | El equipo destino no necesita tener Python instalado                                       |

DOS MODOS DE OPERACIÓN

**Modo panel.** Ventana completa con orbe de estado que cambia a rojo ante amenaza, listado priorizado de hallazgos, pestaña de blindaje y zona de análisis por arrastre.

**Modo consola.** Auditoría por línea de comandos que imprime el reporte completo. Es el modo indicado para levantar la línea base del laboratorio equipo por equipo.

## Principios de diseño defensivo

Una herramienta de seguridad que se instala en equipos ajenos debe justificar cada permiso que pide. Estos seis principios están implementados en el código, y son el argumento más sólido del proyecto ante un jurado.

|                                                                                                                                                                                                          |                                                                                                                                                                                                                                              |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>PRINCIPIO 01</p> <p><b>Solo lectura por defecto</b></p> <p>La vigilancia y la auditoría no modifican absolutamente nada. Observan el estado del equipo y reportan.</p>                                | <p>PRINCIPIO 02</p> <p><b>Ningún cambio en silencio</b></p> <p>Toda corrección se ejecuta elevada y dispara el aviso de administrador de Windows. Si el usuario cancela, el sistema lo informa con honestidad en lugar de simular éxito.</p> |
| <p>PRINCIPIO 03</p> <p><b>Toda acción es reversible</b></p> <p>La cuarentena mueve y registra, jamás elimina. Cada archivo aislado conserva su ruta original y la fecha para poder restaurarlo.</p>      | <p>PRINCIPIO 04</p> <p><b>Funciona sin internet</b></p> <p>Detección, auditoría, corrección y resumen operan en local. Los servicios externos son mejoras opcionales, nunca requisitos.</p>                                                  |
| <p>PRINCIPIO 05</p> <p><b>Alcance estrictamente local</b></p> <p>El sistema solo observa la máquina donde corre. No escanea la red, no sondea otros equipos, no incorpora capacidad ofensiva alguna.</p> | <p>PRINCIPIO 06</p> <p><b>Evidencia en cada hallazgo</b></p> <p>Cada detección adjunta sus datos crudos: identificador de proceso, ruta completa, puerto, dirección remota. La afirmación siempre es verificable.</p>                        |

**Calibración contra falsos positivos.** El motor excluye deliberadamente las carpetas ProgramData y AppData del criterio de rutas sospechosas, porque aplicaciones legítimas y muy comunes se ejecutan desde ahí. Una herramienta que alerta de todo termina ignorada. Menciona esta decisión en la sustentación: demuestra criterio de ingeniería, no solo programación.

## Limitaciones declaradas

Declararlas antes de que las pregunten es una señal de solvencia profesional. Un jurado penaliza mucho más al que oculta un límite que al que lo reconoce.

| LÍMITES CONOCIDOS DEL SISTEMA                                       |                                                                                                                                                                             |
|---------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| LIMITACIÓN                                                          | RESPUESTA PREPARADA                                                                                                                                                         |
| No detecta malware por firmas                                       | Es deliberado. Esa capa la cubre Windows Defender, cuyo estado SENTINEL audita. Son capas complementarias.                                                                  |
| Las heurísticas pueden generar falsos positivos                     | Un instalador legítimo recién descargado se reporta como severidad media. Por eso es media y no crítica, y por eso cada hallazgo trae evidencia para que la persona decida. |
| Requiere privilegios de administrador para la vista completa de red | Sin ellos el sistema avisa expresamente que la visión es limitada, en vez de reportar un falso estado correcto.                                                             |
| Audita un equipo a la vez                                           | La consola centralizada es la primera línea de la hoja de ruta. Hoy se recorre equipo por equipo, que es exactamente lo que la auditoría del PIM requiere.                  |
| La licencia sin servidor no es inviolable                           | Frena la copia casual y permite activaciones reales. Un esquema con servidor de validación sería el siguiente paso comercial.                                               |
| La función de voz avanzada envía contexto a un servicio externo     | Es opcional y se puede desactivar. Con ella apagada, el sistema conserva todas sus capacidades de detección y corrección.                                                   |

## Qué podría hacer

---

Una hoja de ruta creíble vale más que una lista de deseos. Va ordenada por proximidad real de implementación, y la primera fase es la que el propio proyecto necesita.

### Horizonte inmediato — lo que exige el PIM

- **Exportación de auditorías.** Que cada barrido genere un archivo con fecha, equipo anonimizado, hallazgos y puntaje. Sin esto no hay evidencia documental para los anexos.
- **Consolidación automática.** Reunir todas las auditorías en una tabla de frecuencias que produzca el diagrama de Pareto directamente.
- **Reporte imprimible por equipo.** Una hoja por máquina, con puntaje antes y después, firmable por el responsable del aula.

### Horizonte medio — el laboratorio completo

- **Consola central.** Un agente en cada equipo reportando a un panel único: inventario del laboratorio, puntaje por máquina y ranking de lo más urgente.
- **Vigilancia de medios extraíbles.** Registrar cada USB conectado y analizar automáticamente su contenido ejecutable. Es el vector número uno en un colegio y hoy no está cubierto.
- **Persistencia extendida.** Ampliar la detección a tareas programadas, servicios de Windows y suscripciones WMI, que son mecanismos de persistencia más sigilosos que las claves Run.
- **Línea base por equipo.** Fotografiar el estado correcto de una máquina recién preparada y alertar ante cualquier desviación posterior.
- **Aviso al responsable.** Notificación automática al encargado del aula cuando un equipo detecte una amenaza crítica.

### Horizonte largo — producto comercializable

- **Integración con el registro de eventos de Windows** para reconstruir la línea de tiempo de un incidente.
- **Bloqueo preventivo de ejecución** desde carpetas temporales mediante políticas del sistema, pasando de detectar a impedir.
- **Perfil de aula.** Modo restringido pensado para equipos de uso estudiantil.
- **Portal de gestión de licencias** para venta a instituciones.

# Indicadores del proyecto

El PIM se evalúa por mejora demostrable. Estos son los indicadores que SENTINEL produce por sí mismo, con su fórmula y el instrumento que los levanta.

| CUADRO DE INDICADORES                               |                                                                            |                                       |
|-----------------------------------------------------|----------------------------------------------------------------------------|---------------------------------------|
| INDICADOR                                           | FÓRMULA                                                                    | INSTRUMENTO                           |
| Puntaje de blindaje promedio<br>Indicador principal | Suma de puntajes dividida entre número de equipos                          | Auditoría de SENTINEL antes y después |
| Equipos con protocolo obsoleto activo               | Equipos con SMBv1 habilitado sobre el total, en porcentaje                 | Control de blindaje SMBv1             |
| Equipos sin firewall en todos los perfiles          | Equipos con al menos un perfil desactivado sobre el total                  | Control de blindaje de firewall       |
| Hallazgos de severidad alta o superior              | Promedio de hallazgos por equipo                                           | Motor de vigilancia                   |
| Tiempo de auditoría por equipo                      | Minutos de revisión manual frente a segundos automatizados                 | Cronómetro, medición directa          |
| Costo evitado                                       | Incidentes evitados por costo de reinstalación más horas de clase perdidas | Registro histórico del área           |

**El indicador que gana la sustentación.** El tiempo de auditoría. Comprobar manualmente los cinco controles en un equipo toma alrededor de quince minutos a alguien que sepa dónde buscar. SENTINEL lo hace en segundos. Cronometra ambas cosas delante del jurado si te dan el espacio: es la demostración más contundente y la más fácil de entender.

## Cómo presentarlo

### 10.1 Correspondencia con la estructura del PIM

El proyecto ya existe; lo que falta es vestirlo con la estructura que SENATI exige. Este es el reparto del material de este dossier por capítulo.

| QUÉ MATERIAL VA EN CADA CAPÍTULO   |                                                                        |                                   |
|------------------------------------|------------------------------------------------------------------------|-----------------------------------|
| CAPÍTULO                           | CONTENIDO                                                              | DE DÓNDE SALE                     |
| I. Generalidades                   | Datos de la institución educativa, área intervenida, organigrama       | Coordinación del colegio          |
| II. Plan del proyecto              | Problema, objetivos, justificación y marco teórico                     | Secciones 02 y 04 de este dossier |
| III. Situación actual              | Auditoría inicial, Pareto de vulnerabilidades, diagrama causa-efecto   | Trabajo de campo con SENTINEL     |
| IV. Propuesta de mejora            | El sistema: capacidades, arquitectura, principios y plan de despliegue | Secciones 03, 05 y 06             |
| V. Costos                          | Horas de desarrollo, equipamiento, despliegue y capacitación           | Estimación propia                 |
| VI. Evaluación técnica y económica | Puntaje antes y después, costo evitado, relación beneficio-coste       | Sección 09                        |
| VII. Conclusiones                  | Cumplimiento de objetivos con cifras                                   | Resultados medidos                |
| VIII. Recomendaciones              | Continuidad y ampliación                                               | Sección 08                        |

### 10.2 Guion de la demostración en vivo

Ocho minutos, ensayados. La demostración se gana o se pierde en los primeros noventa segundos.



---

00:00

### **Abre con el problema, no con el programa**

Un equipo del laboratorio proyectado. Pregunta al jurado: ¿este equipo, tal como está, es seguro? Nadie puede responder. Ese silencio es tu planteamiento del problema.

---

01:00

### **Auditoría en vivo**

Ejecuta SENTINEL sobre ese equipo. Aparece el puntaje real y el listado priorizado. En un segundo pasaste de una opinión a un número.

---

02:00

### **Explica un hallazgo grave**

Toma el más serio, probablemente SMBv1 o un puerto expuesto, y cuenta la historia de WannaCry en 2017. Conecta la pantalla con un hecho que el jurado recuerda.

---

03:30

### **Corrección delante de ellos**

Pide la corrección por voz. Que se vea el aviso de administrador de Windows y subraya que sin esa autorización no ocurre nada. Vuelve a auditar: el puntaje sube.

---

05:00

### **Análisis de archivo**

Arrastra el archivo de prueba EICAR y muestra el veredicto y la cuarentena. Explica que EICAR es el archivo inofensivo estándar que la industria usa justamente para esto.

---

06:30

### **Cierra con el dato agregado**

Proyecta el puntaje promedio del laboratorio antes y después de la intervención. Un equipo impresiona; el laboratorio completo demuestra impacto.

## Preguntas

Deja el panel abierto y en ejecución mientras respondes. Refuerza que es un sistema vivo, no una captura de pantalla.

**Regla innegociable.** No uses malware real en la demostración, ni siquiera controlado. Usa el archivo de prueba EICAR y, si necesitas mostrar un escenario crítico, el modo de demostración con amenazas simuladas que el sistema ya incorpora. Si recurres a ese modo, **decláralo en voz alta como simulación**. Presentar una amenaza sintética como si fuera real y que el jurado lo descubra hunde la sustentación entera.

## 10.3 Autorización y manejo ético de los datos

Auditar equipos de una institución sin autorización escrita es, en seguridad informática, exactamente la línea que separa a un profesional de un intruso. Este punto no es burocracia: es parte del contenido técnico del proyecto y sube su nivel percibido.

- **Autorización firmada** de la dirección o del responsable del aula antes de tocar el primer equipo, indicando alcance y fechas. Va en anexos.
- **Anonimización de equipos** como PC-01, PC-02 y sucesivos. Ningún nombre de usuario ni dato personal en el documento.
- **Alcance por escrito:** auditoría de configuración y estado, sin acceso a archivos personales ni al contenido de los usuarios.
- **Entrega de resultados a la institución,** independientemente de la nota. Auditaste su infraestructura; los hallazgos les pertenecen.

## 10.4 Materiales de sustentación

- Equipo propio con SENTINEL instalado, más un equipo del laboratorio como caso real.
- Instalador en memoria USB, por si el equipo del ambiente falla.
- Capturas de respaldo de cada paso de la demostración, por si no hay proyección o falla la ejecución en vivo.
- Ficha técnica impresa de una cara para cada miembro del jurado.
- Diagrama de arquitectura ampliado y cuadro de correspondencia con MITRE ATT&CK.
- Carta de autorización firmada y actas de auditoría por equipo.

## 10.5 Preguntas probables del jurado

---

**P.** ¿Esto no es lo mismo que un antivirus?

**R.** No. Un antivirus busca archivos maliciosos conocidos. SENTINEL audita cómo está configurado el equipo y qué comportamientos anómalos ocurren ahora. De hecho verifica que el antivirus esté activo: son capas complementarias, no competidoras.

---

**P.** ¿Qué pasa si detecta algo que en realidad es legítimo?

**R.** Ocurre, y por eso las heurísticas están calibradas por severidad y cada hallazgo trae su evidencia. El sistema informa y recomienda, la persona decide. Además se excluyeron deliberadamente carpetas donde corre software legítimo común, para evitar alertas inútiles.

---

**P.** ¿Usted programó todo esto?

**R.** Sí. Dos mil cuatrocientas sesenta y nueve líneas de Python propias organizadas en diecinueve módulos, más la interfaz. Puedo abrir cualquier archivo del proyecto y explicarlo.

---

**P.** ¿Es seguro instalarlo en los equipos del colegio?

**R.** La vigilancia es de solo lectura: no modifica nada. Las únicas operaciones que alteran el sistema son las cinco correcciones de blindaje, cada una ejecutada bajo el aviso de administrador de Windows. Y la cuarentena nunca borra: mueve y registra para poder revertir.

---

**P.** ¿Se puede usar para atacar otros equipos?

**R.** No. El sistema solo observa la máquina donde corre. No escanea la red ni sondea otros equipos. No hay una sola función ofensiva en el código, y es una decisión de diseño declarada.

---

**P.** ¿Por qué estas cinco configuraciones y no otras?

**R.** Porque corresponden a áreas de endurecimiento de los CIS Benchmarks, la referencia internacional de configuración segura de Windows, y cada una se asocia a una técnica de ataque catalogada en MITRE ATT&CK.

---

**P. ¿Depende de inteligencia artificial para funcionar?**

- R.** No. Detección, auditoría, corrección y resumen funcionan en local y sin internet. La inteligencia artificial mejora la explicación y habilita el control por voz, pero es opcional: si se apaga, el sistema conserva todas sus capacidades de seguridad.

---

**P. ¿Cuánto costaría implementarlo en todo el colegio?**

- R.** El desarrollo ya está hecho. El costo de despliegue es tiempo de instalación por equipo más una capacitación breve al responsable del aula. Comparado con una sola reinstalación completa de un equipo infectado, se paga solo.

---

**P. ¿Qué sigue después de esto?**

- R.** La consola central: un agente en cada equipo reportando a un panel único, para ver el estado del laboratorio completo sin recorrerlo máquina por máquina. Es la primera línea de la hoja de ruta.

# Ficha técnica

|                                 |                                                                              |
|---------------------------------|------------------------------------------------------------------------------|
| RESUMEN PARA ENTREGAR AL JURADO |                                                                              |
| Nombre                          | SENTINEL                                                                     |
| Categoría                       | Auditoría de configuración y vigilancia defensiva de endpoint                |
| Plataforma                      | Windows 10 y 11 de 64 bits                                                   |
| Modos                           | Panel gráfico y auditoría por consola                                        |
| Clases de hallazgo              | 8, sobre procesos, red y arranque automático                                 |
| Controles de blindaje           | 5, todos con corrección automática                                           |
| Indicador que produce           | Puntaje de blindaje de 0 a 100                                               |
| Frecuencia de vigilancia        | Cada 60 segundos                                                             |
| Referencias técnicas            | MITRE ATT&CK, CIS Benchmarks para Windows, NIST Cybersecurity Framework      |
| Requisitos                      | Ninguna dependencia previa; privilegios de administrador para vista completa |
| Conectividad                    | Funciona sin internet; servicios externos opcionales                         |
| Naturaleza                      | Exclusivamente defensivo y de alcance local                                  |

**Una línea para memorizar.** SENTINEL le pone un número a la seguridad de un equipo, explica en lenguaje claro por qué ese número es bajo y lo sube con autorización del usuario. Eso es todo el proyecto en una frase, y es con lo que conviene abrir la sustentación.